COMPTIA SECURITY+ SY0-701 | DOMAIN 5 · SECURITY PROGRAM MANAGEMENT AND OVERSIGHT (20%)

Security+ 5.6 · User Training

Mestre CyberSec · **Lesson 5.6 — User Training** (4:31) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Quem: employees, management, third-parties/fornecedor; como: presencial/online/email/CTF; frequência: na contratação + periódico + após incidente; customização por função (executivo: whaling; financeiro: BEC).

💡 Key Exam Highlights & Critical Concepts

- Treina POR FUNÇÃO: executivo recebe whaling; financeiro BEC
- Frequência: contratação + periódico + após incidente

🎯 Exam Tips & Typical CompTIA Scenarios

- 'training customized based on job role'=role-based awareness training

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 5.6 — User Training)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Security Awareness Training (SAT)

Formal education that teaches employees to recognize and avoid security threats such as phishing, social engineering, and password attacks. CompTIA emphasizes that it must be ongoing, role-relevant, and reinforced by policy.

⚠️ ***Exam Trap:*** *Se a questão pede programa geral de treinamento de usuários, procure 'security awareness training'; se menciona adaptação ao cargo, é role-based awareness training.*

• Role-Based Awareness Training (N/A)

Security training customized to the risks and duties of a specific job role, such as executives receiving whaling training and finance staff receiving BEC training.

⚠️ ***Exam Trap:*** *Gatilho: 'training customized based on job role' = role-based awareness training. Não confunda com treinamento genérico para todos.*

• Whaling (N/A)

A phishing attack specifically targeting high-level executives or other senior leaders, often using highly customized messages to steal credentials or authorize fraudulent transfers.

⚠️ ***Exam Trap:*** *Gatilho: executivos/CEO/CFO = whaling. O treinamento por função deve dar whaling awareness a executivos.*

• Business Email Compromise (BEC)

A fraud scheme in which an attacker impersonates or compromises a business email account to trick employees into transferring funds or revealing sensitive data. Finance and billing staff are common targets.

⚠️ ***Exam Trap:*** *Gatilho: funcionário do financeiro/contas a pagar + e-mail de CEO solicitando transferência = BEC. Treinamento por função para financeiro deve cobrir BEC.*

• Capture the Flag (CTF)

A hands-on cybersecurity exercise or competition where participants solve security challenges to find hidden flags. In user training, it can build practical skills and engagement.

⚠️ ***Exam Trap:*** *Lembre: CTF é método de treinamento prático/gamificado citado pela CompTIA. Se a questão mencionar desafios práticos ou competição, CTF é a resposta provável.*

• **Onboarding Security Training (N/A)**
Security awareness training provided when a new employee, contractor, or third party is hired or begins work. It establishes baseline policy and security expectations.

⚠️ ***Exam Trap:*** *Frequência: na contratação/onboarding. CompTIA espera treinamento inicial + periódico + após incidente; não é apenas uma vez.*

• **Post-Incident Training (N/A)**
Additional security awareness training delivered after a security incident to address lessons learned, updated threats, or specific user mistakes. It helps prevent recurrence.

⚠️ ***Exam Trap:*** *Gatilho: 'após um incidente' = retreinamento/treinamento pós-incidente. A frequência inclui contratação, periódico e após incidente.*

• **Third-Party Security Training (N/A)**
Security awareness training for vendors, suppliers, contractors, and other external parties who access organizational systems or data. It ensures third parties understand policies and reporting requirements.

⚠️ ***Exam Trap:*** *Gatilho: fornecedor/terceiro/contratado = third-party training. A CompTIA inclui terceiros no escopo de treinamento de usuários.*

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A fast-growing company assigns email and application accounts to new hires on their first morning. Security awareness training is only offered during a monthly session, so some new employees work for weeks without it. A recent review shows that a new hire clicked a credential-harvesting link during the first week. Which control should the security team implement to reduce this risk?

A) Require new hires to complete onboarding security training before email and application access is provisioned.

B) Send a monthly security newsletter to all staff and rely on managers to reinforce key points.

C) Delay security awareness training until the employee has passed the probation period.

D) Publish the acceptable use policy on the intranet and ask employees to review it when convenient.

QUESTION 2 · EXAM SCENARIO

The finance department at a retailer follows a generic annual security awareness module. A fraudster recently impersonated the CFO by email and requested an urgent wire transfer to a new bank account. The finance employee did not verify the request through a second channel. Which training improvement should the security team prioritize?

A) Provide whaling awareness only to the board of directors and executive assistants.

B) Run a Capture the Flag event for software developers to improve secure coding.

C) Deliver role-based training for finance staff on business email compromise, urgent payment fraud, and out-of-band verification procedures.

D) Require all vendors to sign an acceptable use policy before remote access.

QUESTION 3 · EXAM SCENARIO

A multinational company has executives who travel frequently and delegate email triage to executive assistants. A recent attack impersonated a board member and asked the CEO to open a malicious document about a confidential acquisition. Current training is the same for all employees. Which training approach best addresses this threat?

A) Train only the IT service desk on password reset procedures.

B) Provide whaling-focused awareness training to executives and their assistants, covering impersonation, urgency, and verification.

C) Require all employees to complete an annual generic phishing module.

D) Give third-party vendors access to the company learning portal.

QUESTION 4 · EXAM SCENARIO

A manufacturing firm allows a supplier's support engineers to remotely access maintenance systems. One supplier employee reused a compromised password, and the attacker used that account to move laterally. The contract requires security compliance but does not specify awareness training. What should the firm implement for third-party risk?

A) Require third-party personnel with system access to complete company security awareness training before access and on a recurring basis.

B) Add supplier email addresses to the company's internal security newsletter.

C) Disable multifactor authentication for supplier accounts to reduce support calls.

D) Invite supplier employees to the internal Capture the Flag competition only.

QUESTION 5 · EXAM SCENARIO

After a phishing campaign led to ransomware on several endpoints, the incident response team found that employees in two departments had not received security training in over 18 months. Leadership wants to reduce the chance of recurrence. Which action is most appropriate?

A) Wait until the next annual training cycle to avoid disrupting operations.

B) Send a one-time email warning employees to be more careful with attachments.

C) Conduct post-incident training for affected departments and update the awareness program based on lessons learned.

D) Terminate all employees who interacted with the phishing email.

QUESTION 6 · EXAM SCENARIO

A security manager wants to improve the practical skills of the internal IT and security staff. The current online slides explain attack techniques but do not let staff practice detection or response in a safe environment. Which training method best meets this goal?

A) Require staff to read the incident response plan and sign an acknowledgment.

B) Replace all awareness training with quarterly phishing simulations.

C) Provide executive whaling training to the IT staff.

D) Organize a Capture the Flag exercise with scenarios mapped to internal systems, threats, and response procedures.

QUESTION 7 · EXAM SCENARIO

A software company provides security awareness training only during onboarding. After two years, phishing simulation click rates have steadily increased, and employees report they do not remember reporting procedures. Which program change should be made?

A) Retrain employees only after a major security incident occurs.

B) Implement recurring awareness training at least annually, supplemented by periodic short campaigns and reminders.

C) Send the security policy once a year for signature without additional instruction.

D) Increase email filtering rules and reduce the need for employee awareness.

QUESTION 8 · EXAM SCENARIO

The CEO asks the security team to make awareness training more relevant. Executives receive highly targeted emails about mergers, legal matters, and wire transfers, but the current mandatory module uses examples about office clean desks and generic spam. Which approach best customizes training for this group?

A) Keep the same generic module for all employees to ensure consistency.

B) Exempt executives from training because they have executive assistants.

C) Provide only finance-specific BEC training to the CEO and board.

D) Deliver role-based executive training focused on whaling, social engineering, and secure reporting channels.

QUESTION 9 · EXAM SCENARIO

A global company has employees across many time zones. In-person security awareness sessions at headquarters have low attendance, and branch offices receive inconsistent messages. The security team needs a scalable method with completion tracking. Which delivery method should be used?

A) Mandatory in-person sessions at headquarters recorded and posted on a shared drive.

B) A single security email sent to all employees at the start of each year.

C) Email-based microlearning modules with online self-paced courses and automated reminders.

D) Delegating all training to local managers without centralized materials.

QUESTION 10 · EXAM SCENARIO

An attacker called the IT service desk, claimed to be a traveling executive, and convinced a technician to reset multifactor authentication for an account. The attacker then accessed email. The service desk has only completed general annual awareness training. Which training should be prioritized?

A) Additional whaling awareness for all executives and board members.

B) Role-based training for service desk staff on identity verification, social engineering, and MFA reset procedures.

C) Finance-specific BEC training for the accounting department.

D) A Capture the Flag event for software developers focused on web exploitation.

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option A — Require new hires to complete onboarding security training before email and application access is provisioned.

Onboarding security training should occur before or at the time access is granted, especially for email and core applications. It establishes secure behavior early. Newsletters, delayed training, and passive policy posting do not provide timely, tracked onboarding instruction.

Question 2: Option C — Deliver role-based training for finance staff on business email compromise, urgent payment fraud, and out-of-band verification procedures.

Finance staff need role-specific BEC training, including verification of payment changes through a separate trusted channel. Whaling training is for executives, CTF is for technical staff, and a vendor policy does not address finance workflow.

Question 3: Option B — Provide whaling-focused awareness training to executives and their assistants, covering impersonation, urgency, and verification.

Whaling targets senior executives and those who support them, such as assistants. Training should be role-based and cover impersonation, pressure tactics, and verification of sensitive requests. Generic annual training and unrelated role modules do not address executive-specific exposure.

Question 4: Option A — Require third-party personnel with system access to complete company security awareness training before access and on a recurring basis.

Third parties with access should receive security awareness training appropriate to their access, including credential handling and reporting, before access and periodically. A newsletter is not tracked training, disabling MFA weakens security, and CTF alone is not a comprehensive control.

Question 5: Option C — Conduct post-incident training for affected departments and update the awareness program based on lessons learned.

Post-incident training should be delivered promptly to reinforce lessons from the event and improve future response. Waiting, sending only a warning, or relying on punishment does not build lasting awareness or address the control gap.

Question 6: Option D — Organize a Capture the Flag exercise with scenarios mapped to internal systems, threats, and response procedures.

CTF exercises provide hands-on, safe practice for technical staff and can reinforce detection, analysis, and response skills. Reading a plan, phishing simulations alone, or mismatched executive training do not provide the same practical technical development.

Question 7: Option B — Implement recurring awareness training at least annually, supplemented by periodic short campaigns and reminders.

Security awareness requires continuous reinforcement. Recurring training plus periodic campaigns helps maintain knowledge and reporting habits. Training only after incidents, policy signatures, or technical controls alone do not address human-risk retention.

Question 8: Option D — Deliver role-based executive training focused on whaling, social engineering, and secure reporting channels.

Executive training should reflect the whaling and social engineering threats they face. Role-based content improves relevance and retention. Generic content, exemptions, and finance-only training do not cover the broader executive threat profile.

Question 9: Option C — Email-based microlearning modules with online self-paced courses and automated reminders.

Online self-paced modules with tracking and email reminders provide scalable, consistent delivery across time zones and allow completion monitoring. HQ-only sessions, a single email, or unmanaged delegation do not ensure consistent tracked training.

Question 10: Option B — Role-based training for service desk staff on identity verification, social engineering, and MFA reset procedures.

The service desk was targeted through social engineering and a sensitive identity procedure. Role-based training should focus on verifying identities, resisting pressure, and following MFA reset controls. Other audience-specific trainings do not address the service desk workflow.